AAA and Access Control

6COSC019W- Cyber Security

Usama Arusi

March 23, 2026

Prepared by Dr Ayman El Hajjar

UNIVERSITY OF WESTMINSTER

Overview

1. Access Control
2. Access Control principles
3. Logical Access Control
4. Access Control Models
5. Authentication, Authorisation & Accountability (AAA)

Access Control definition

Protecting Security Assets

The ultimate goal for any security practitioner is to be able to secure all assets of their organisation.

Defining Access Control

- Access Control is the process of protecting a resource so that it is used only by those allowed to.
- Mitigations put into place to protect a resource from a threat such as to prevent unauthorised use.

Types of Access control

Physical Access Control

- Deciding which users can get access a physical environment
- Cards control access to physical resources or fingerprint (less used)
- For example: Used at office doors or server rooms.

Logical Access Control

- Deciding which users can get into a system
- Monitoring what each user does on that system
- Restraining or influencing a user's behaviour on that system

Access Control Functions

- **Identification**: Who is asking to access the asset?
  - Subjects supplying identification information
  - Username, user ID, account number
- **Authentication**: Can their identities be verified?
  - Verifying the identification information
  - Passphrase, PIN, biometric, password, OTP
- **Authorisation**: What can the requester access and do?
  - Using criteria to determine what the subjects can do on objects
  - "I know who you are, I will allow you to do what you are allowed to ?”
- **Accountability**: How are actions traced to an individual to ensure the person who makes data or system changes can be identified?
  - Audit logs and/or real-time monitoring to track subject activities with objects

Access Control Components

Subject

An entity capable of Accessing objects

Three classes
- Owner
- Group
- World

Object

A resource to which access is controlled

Entity used to contain and/or receive information

Access Rights

Describe the way in which a subject may access an object

Could include
- Read
- Write
- Execute
- Delete
- Create
- Search

Policy Definition and Policy Enforcement Phases

- **Policy Definition phase**: We start by defining Who has access and what systems or resources they can use.
  - Tied to the authorisation phase
- Then, the policy enforcement phase Grants/Rejects requests for access based on the authorisations defined in the first phase.
  - Tied to identification, authentication, & accountability

An example- A student Virtual learning environment

- **Policy definition phase:** Students are only authorised to see contents of their modules. They cannot edit.
- **Enforcement phase:** For each student who access the system:
  - Identified by their username and authenticated by their password. Access is based on the policy definition phase.

General Principles

- Files and folders are managed by the operating system
- Applications, including shells, access files through an API
- Access control entry (ACE) through a policy
  - Allow/deny a certain type of access to a file/folder by user/group
- Access control list (ACL)
  - Collection of ACEs for a file/folder

- How OS Stores File References
  - Windows $\rightarrow$ Tree Structure: Each file/folder has only one parent; no hard links.
  - Linux $\rightarrow$ DAG Structure: Hard links allow files to have multiple parents (same inode in different locations).
- An Operating system file handles files when in use using an unique identifier, such as when the file is opened, closed, or modified.

Types of Policies

Closed policy

Give Tom Read access to "**foo**"

Tom: I would like to Read "**foo**"

Access Allowed

Tom: I would like to Read "**bar**"

Access Denied

Open policy

Deny Tom Read access to "**foo**"

Tom: I would like to Read "**foo**"

Access Denied

Tom: I would like to Read "**bar**"

Access Allowed

Close policy with negative authorisation and Deny policy

Give Tom Read/Write access to "**foo**"

AND (In this order)

Deny Tom Write access to "**foo**"

Tom: I would like to Read "**foo**"

Access Allowed

Tom: I would like to write to "**foo**"

Access Denied

Access Control Matrix example

- Each entry in the matrix indicates the access rights of a particular subject for a particular object

		Objects			
		File 1	**File 2**	**File 3**	**File 4**
Subjects	**User A**	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

Enforcing Access Control

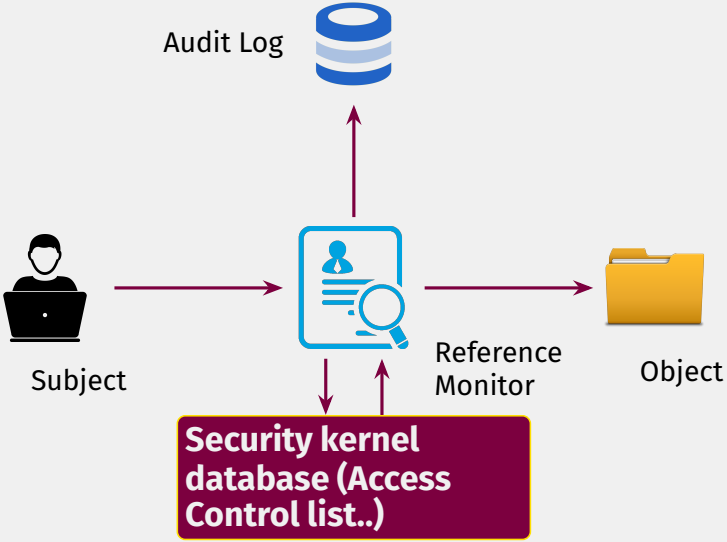
The Security Kernel

- Enforces access control for computer systems
- Central point of access control
- Implements the reference monitor concept.

How Access Control is enforced

- The subject requests access to an object. The security kernel intercepts the request.
- The security kernel refers to its rules base, also known as the security kernel database to allow or deny access.
- All access requests handled by the system are logged for later tracking and analysis.

Enforcing Access Control



Authentication Types

Authentication by Knowledge: Something you know

- Passwords, passphrases. PIN number

Authentication by Ownership: Something you own

- Synchronous token- Calculates a number at both the authentication server and the device
  - Time-based synchronization, i.e. software authenticator
  - Event-based synchronization, i.e. SMS one time password
- Asynchronous token: Fixed, no calculation is needed as long as you prove you physically have it, you can access
  - USB token or Smart card

Authentication Types

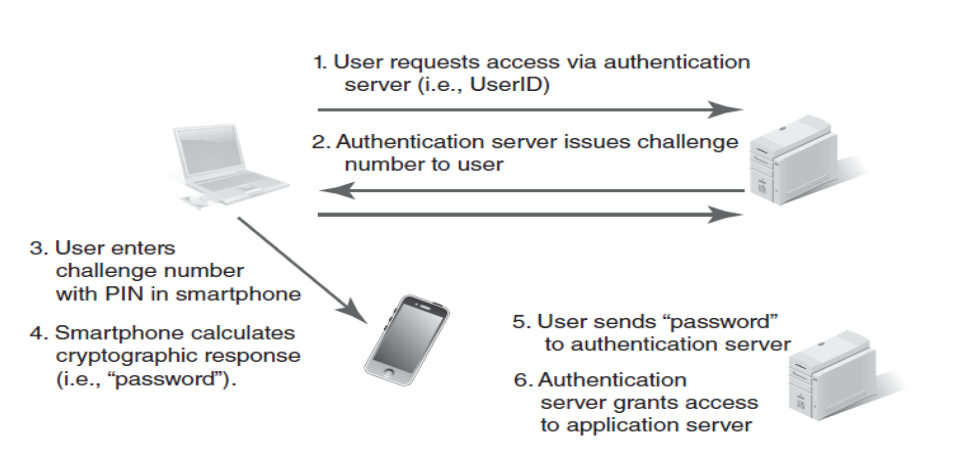
Authentication by Characteristics: Something unique to you

- This can be:
  - ❑ **Biometrics** - Something Static, What are you
    - Fingerprint, facial recognition, hand geometry, Retina scan
  - ❑ Something Dynamic such as What you do!
    - Voice patterns, keystroke dynamics, signature dynamics

Authentication by Location: Somewhere you are

- Location
  - Strong indicator of authenticity

Synchronous Token Challenge-Response



Access Control Models

- All access control models are built on the **security operation principles** listed below:
  - **Need to know** This principle ensures that subjects are granted access only to what they need to know for their work tasks and job functions.
  - **Least privilege** This principle ensures that subjects are granted only the privileges they need to perform their work tasks and job functions.
  - **Separation of privileges** This principle ensures that sensitive functions are split into tasks performed by two or more employees.

Access Control Models

- An access control model is a framework that dictates how subjects access objects.
- It uses access control technologies and security mechanisms to enforce the rules and objectives of the model.
- There are many types of access control models. We will look at some of the most widely used ones:
  - Discretionary Access Control (DAC)
  - Mandatory Access Control (MAC)
  - Role Based Access Control (RBAC)
  - Rule Based Access Control (RuBAC)
  - Attribute-based access control (ABAC)
- Each model type uses different methods to control how subjects access objects
- Each model has its own merits and limitations.

Discretionary Access Control (DAC)

- The principle of discretionary access control (DAC) dictates that the information owner is the one who decides who gets to access the system(s)
- Access is granted based on the discretion of the owner of the resource. The owner can assign permissions to other users.
- The resource owner (e.g., a file creator) can set access permissions (read, write, execute) for other users or groups. Permissions can be modified at any time by the owner.
- A user creates a document and decides who can view or edit it, similar to file-sharing permissions in Windows or Google Drive.
- DAC is simple to implement but harder to manage in large organisations since access control depends on individual owners.

Non-discretionary Access Control models

- Access rules are closely managed by security administrator, not system owner or ordinary users
- Sensitive files are write-protected for integrity and readable only by authorised users
- More secure than discretionary access control
- Ensures that system security is enforced and tamper-proof.

Mandatory Access Control (MAC)

- In MAC, access is enforced by a central authority based on security classifications, and users cannot change permissions.
- The system assigns security labels (e.g., "Top Secret," "Confidential") to users and data. Users can only access data if their clearance level matches the data classification.
- Often used in military and government systems with labels given to objects and access is given to subject based on security clearance level.
  - **Example**: Government agencies may restrict access to classified documents based on a user's security clearance level (e.g., only users with "Top Secret" clearance can view certain files).
- MAC is considered highly secure but do not offer any flexibility.
- Used in Military, government, and high-security environments where strict data control is required.

Role Based Access Control (RBAC)

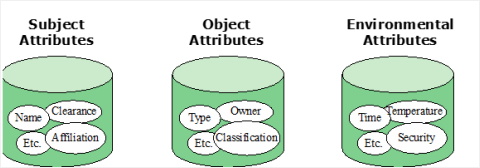
- In Role-based access control access is granted based on predefined roles assigned to users.
- Users are assigned roles (e.g., "Manager," "HR," "IT Admin"), and each role has specific access rights.
- RBAC can be easily applied in large organisations where permissions are tied to roles, not individual users.
  - Example: A "Manager" role may have access to employee performance data, while a "Staff" role does not.

Rule Based Access Control (RuBAC)

- In RuBAC, access is granted based on **predefined rules** that evaluate attributes such as time, location, device type, or other conditions.
- A system administrator sets rules, and when a user requests access, the system checks if the request meets the rule criteria.
  - **Example:** A company may allow access to a database only during business hours or only from a corporate network.
- BuBAC works well in dynamic environments where access needs to be condition-based rather than strictly role-based or dependent on a single attribute
- RuBAC is highly flexible but complex to manage if rules increase.

Attribute-Based Access Control (ABAC)

- In ABAC, access is granted based on attributes of users, resources, actions, and environmental conditions.
- Instead of assigning roles, ABAC evaluates multiple attributes (e.g., user department, device type, location, time) to determine access permissions dynamically.
- ABAC is highly scalable as it allows fine-grained control without needing to create many predefined roles.
- ABAC is often used in organisations that require dynamic and context-aware access control.



Authentication,authorisation, and Accounting (AAA)

- AAA is a security framework that controls user access to systems by verifying identity (Authentication), defining access rights (Authorisation), and tracking user activities (Accounting).
  - Example: A corporate VPN requires employees to log in with credentials (Authentication), allows only certain users to access sensitive files (Authorisation), and records login history and file access (Accounting).
- AAA is suitable for both small and large organisations, ensuring secure and accountable access management.

Identity and Access Management (IAM)

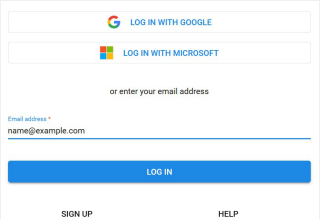
- IAM is a framework of policies and technologies that ensures the right individuals have appropriate access to enterprise resources at the right time.
- IAM manages user identities and credentials. Assigns and enforces access permissions based on policies.
- IAM supports Single Sign-On (SSO).
  - In an SSO system, users have one password for all corporate and back-office systems and applications they need to perform their jobs
- Single Sign-On mechanisms include
  - Kerberos (for network authentication)
  - Federated Identities (for web-based authentication)

Kerberos

- Kerberos is designed to provide authentication for client/server applications by using symmetric-key cryptography
- A free implementation available from MIT
- Works by assigning a unique key, called a ticket, to each user
- User logs in once and then can access all resources based on the permission level associated with the ticket

Federated Identities

- Federated identity allows users to authenticate across multiple services using a single set of credentials, managed by a trusted identity provider (IdP).
- This reduces the need for creating separate usernames and passwords for different services.
- Microsoft, Facebook, and Google provide identity and trust management services, by using protocols for authentication and authorisation.



References

- The lecture notes and contents were compiled from my own notes and from various sources.
- Figures and tables are from the recommended books
- **The lecture notes are very detailed. If you attend the lecture, you should be able to understand the topics.**
- **You can use any of the recommended readings! You do not need to read all the chapters!**
- **Recommended Readings note:** Focus on what was covered in the class.
  - **Chapter 6: Access Controls**, Fundamentals of Information Systems Security.